

Third-Party Vendor Security Assessment Questionnaire

This questionnaire is used to evaluate the information security posture of third-party vendors prior to onboarding or annual renewal. All fields are required unless marked optional. Responses may be verified through supporting documentation.

A. Organizational Information Security

1. Do you have a member of your organization with dedicated information security duties?

Response: _____

2. Is a background check required for all employees who access and handle third-party data?

Response: _____

3. Does the organization have documented, written information security policies?

Response: _____

4. Does the organization have a written password policy that specifies required structure and complexity?

Response: _____

5. How do you verify and enforce password strength across user accounts?

Response: _____

6. Do all staff receive information security awareness training at least annually?

Response: _____

7. Does the organization have a formal change control process for IT system changes?

Response: _____

8. Has the organization implemented an IT governance framework such as ITIL or ISO 27001?

Response: _____

B. General Security Controls

9. Is antivirus / endpoint protection software installed and active on all data processing servers?

Response: _____

10. Is antivirus / endpoint protection software installed and active on all workstations?

Response: _____

11. Are operating system and security patches applied to workstations on a routine schedule?

Response: _____

12. Are operating system and security patches applied to servers on a routine schedule?

Response: _____

13. Are patches tested in a staging environment prior to deployment to production?

Response: _____

14. Do all employees have a unique login ID when accessing systems containing sensitive data?

Response: _____

15. Does the organization have documented security measures in place for data protection?

Response: _____

16. Is access to systems containing sensitive or confidential data restricted on a need-to-know basis?

Response: _____

17. Is physical access to data processing equipment (servers, network gear) restricted and logged?

Response: _____

18. Does the organization have a documented process for secure disposal of IT equipment and media?

Response: _____

C. Network Security

19. Are network perimeters protected by firewalls with documented rule sets?

Response: _____

20. Is regular network vulnerability scanning performed? If so, how frequently?

Response: _____

21. Does the organization use Intrusion Detection Systems (IDS) or Intrusion Prevention Systems (IPS)?

Response: _____

22. Are employees required to use a VPN when accessing organizational systems from remote locations?

Response: _____

23. If wireless access is permitted, how is the wireless network secured and segmented?

Response: _____

24. Is sensitive data and data communications encrypted in transit (e.g., TLS/SSL)?

Response: _____

25. Is there formal control and logging of access to System Administrator privileges?

Response: _____

26. Are servers configured to capture audit logs of who accessed the system and what changes were made?

Response: _____

D. Data Storage & Backup

27. Are production systems backed up according to a documented and tested schedule?

Response: _____

28. Has the backup and recovery process been tested and verified within the last 12 months?

Response: _____

29. Does the organization store backups at an offsite or geographically separated location?

Response: _____

30. Does the organization encrypt backups both in transit and at rest?

Response: _____

31. Does the organization replicate or store data to locations outside of Canada / the United States?

Response: _____

32. Does the organization outsource its data storage? If yes, to which providers?

Response: _____

33. Is customer data logically isolated in its own instance within the environment?

Response: _____

E. Business Continuity & Incident Response

34. Does the organization have documented Disaster Recovery (DR) plans for data processing facilities?

Response: _____

35. Does the organization have documented Business Continuity Plans (BCP)?

Response: _____

36. Are data centres and computer rooms protected against fire, flood, and environmental hazards?

Response: _____

37. Does the organization maintain a hot or warm recovery site for critical systems?

Response: _____

38. Does the organization have a formal Incident Response plan, and is it tested annually?

Response: _____

39. In the event of a data breach involving client data, what is the notification timeline and process?

Response: _____

40. Has the organization experienced an information security breach in the past three to five years?

Response: _____

F. Third-Party & Audit Controls

41. Does the organization obtain a SOC 2 Type II or SSAE-18 report? If so, please provide the latest.

Response: _____

42. If a SOC 2 report is not available, does the organization allow clients the right to audit?

Response: _____

43. Are there written agreements with all sub-processors or third parties that handle client data?

Response: _____

44. How often does the organization perform periodic reviews of its third parties with data access?

Response: _____

45. Will client data be hosted by a third-party cloud or hosting provider? If yes, name the provider.

Response: _____

46. Does the organization have a current VPAT or accessibility certification?

Response: _____

G. Regulatory & Compliance

47. Is the organization PCI DSS compliant if credit card data is processed on behalf of clients?

Response: _____

48. Does the organization comply with applicable privacy regulations (e.g., PIPEDA, GDPR, CCPA)?

Response: _____

49. Has the organization completed a formal risk assessment in the past 12 months?

Response: _____

50. Does the organization carry cyber liability insurance? If yes, what is the coverage amount?

Response: _____